

Security+ 2.4 · On-path Attacks

Mestre CyberSec — PDF baseado na aula do Professor Messer · 2.4 — On-path Attacks (5:30) · [vídeo original ↗](#) · [YouTube ↗](#)

On-path (antigo man-in-the-middle): atacante fica no MEIO da comunicação e INTERCEPTA ou ALTERA o tráfego. ARP spoofing (mentira no MAC table local — o tráfego passa pelo atacante); evil twin AP; DNS poisoning. Defesa: TLS em tudo (o S importa), VPN em rede pública, ARP inspection.

💡 Highlights que a prova cobra

- On-path (antes MITM): intercepta e/ou altera comunicação
- ARP spoofing: mentira o MAC — redireciona tráfego ao atacante
- Defesa nº1: HTTPS em tudo (o TLS autentica o endpoint)

🎯 Dicas de prova

- 'traffic intercepted between two parties' = on-path/MITM

Cenário clássico: Cenário: 'computador dentro da rede recebe o tráfego que deveria ir pra outra máquina' = ARP spoofing (a base de on-path).

✅ Perguntas de treino (10 questões)

Gabarito no fim. Tenta responder SEM olhar.

1. Atacante se posiciona entre duas partes e intercepta/altera a comunicação. Isso é:

- A) Ataque on-path (MITM)
- B) Negação de serviço
- C) SQL injection
- D) Força bruta

2. Qual tipo de ataque explora vulnerabilidades antes que um patch esteja disponível?

- A)** Ataque de dia zero (Zero-day)
- B)** Ataque DDoS
- C)** Ataque de força bruta
- D)** Ataque Man-in-the-Middle

3. Cenário corporativo (On-path Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'On-path (antes MITM): intercepta e/ou altera comunicação'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: On-path (antes MITM): intercepta e/ou altera comunicação...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

4. Cenário corporativo (On-path Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'ARP spoofing: mentira o MAC — redireciona tráfego ao atacante'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: ARP spoofing: mentira o MAC — redireciona tráfego ao atacante...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

5. Cenário corporativo (On-path Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Defesa nº1: HTTPS em tudo (o TLS autentica o endpoint)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Defesa nº1: HTTPS em tudo (o TLS autentica o endpoint)...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (On-path Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: "traffic intercepted between two parties" = on-path/MITM'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'traffic intercepted between two parties' = on-path/MITM...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (On-path Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Cenário: 'computador dentro da rede recebe o tráfego que deveria ir pra outra máquina' = ARP spoofing (a base de on-path)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Cenário: 'computador dentro da rede recebe o tráfego que deveria ir pra out...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (On-path Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'On-path (antes MITM): intercepta e/ou altera comunicação'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: On-path (antes MITM): intercepta e/ou altera comunicação...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (On-path Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'ARP spoofing: mentira o MAC — redireciona tráfego ao atacante'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: ARP spoofing: mentira o MAC — redireciona tráfego ao atacante...

10. Cenário corporativo (On-path Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Defesa nº1: HTTPS em tudo (o TLS autentica o endpoint)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Defesa nº1: HTTPS em tudo (o TLS autentica o endpoint)...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO

- 1) A — Ataque on-path (MITM).** On-path (antigo 'man-in-the-middle') = fica no meio do tráfego lendo/alterando. DoS derruba serviço; SQLi injeta comando no banco; força bruta testa senhas.
- 2) A — Ataque de dia zero (Zero-day).** Zero-day é uma vulnerabilidade recém-descoberta que é explorada antes do desenvolvedor ter conhecimento ou lançar correção (dia zero de conhecimento).
- 3) B — Implementar a solução correspondente: On-path (antes MITM): intercepta e/ou alte.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (On-path Attacks): On-path (antes MITM): intercepta e/ou altera comunicação. As demais alternativas configuram violações graves de confidencialidade.
- 4) B — Implementar a solução correspondente: ARP spoofing: mentira o MAC — redireciona .** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (On-path Attacks): ARP spoofing: mentira o MAC — redireciona tráfego ao atacante. As demais alternativas configuram violações graves de confidencialidade.
- 5) C — Implementar a solução correspondente: Defesa nº1: HTTPS em tudo (o TLS autêntica).** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (On-path Attacks): Defesa nº1: HTTPS em tudo (o TLS autêntica o endpoint). As demais alternativas configuram violações graves de confidencialidade.
- 6) B — Implementar a solução correspondente: 'traffic intercepted between two parties' .** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (On-path Attacks): 'traffic intercepted between two parties' = on-path/MITM. As demais alternativas configuram violações graves de confidencialidade.
- 7) A — Implementar a solução correspondente: Cenário: 'computador dentro da rede recebe.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (On-path Attacks): Cenário: 'computador dentro da rede recebe o tráfego que deveria ir para outra máquina' = ARP spoofing (a base de on-path).
- 8) A — Implementar a solução correspondente: On-path (antes MITM): intercepta e/ou alte.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (On-path Attacks): On-path (antes MITM): intercepta e/ou altera comunicação. As demais alternativas configuram violações graves de confidencialidade.
- 9) D — Implementar a solução correspondente: ARP spoofing: mentira o MAC — redireciona .** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (On-path Attacks): ARP spoofing: mentira o MAC — redireciona tráfego ao atacante. As demais alternativas configuram violações graves de confidencialidade.
- 10) B — Implementar a solução correspondente: Defesa nº1: HTTPS em tudo (o TLS autêntica).** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (On-path Attacks): Defesa nº1: HTTPS em tudo (o TLS autêntica o endpoint). As demais alternativas configuram violações graves de confidencialidade.

